

STARTER TEMPLATE · ADAPT BEFORE ADOPTION

# AI Use Policy Starter

A starter policy your team can adapt in an afternoon. Defines allowed tools, allowed data, review requirements, and an incident path.

## WHO IT IS FOR

Compliance, risk, and senior management

## FILL TIME

8 min

## WHAT'S INSIDE

- 01 Purpose
- 02 Allowed tools
- 03 Allowed data
- 04 Human-in-the-loop requirement
- 05 Documentation
- 06 Incidents
- 07 Review cycle

## SECTION 01

## Purpose

This policy governs how staff at [Institution] use generative AI tools in the course of work. It applies to any tool that takes free-text input and returns generated text, images, or code — whether vendor-hosted (e.g., Claude, ChatGPT, Gemini), embedded in a vendor product, or self-hosted.

## SECTION 02

## Allowed tools

Only AI tools on the approved list may be used for institution work. The approved list is maintained by [Owner role] and reviewed at minimum quarterly.

- a Tools on the approved list have a signed vendor agreement covering data handling.
- a Personal accounts on consumer AI services are prohibited for any institution data.
- a A tool moves to the approved list only after Compliance and InfoSec sign-off.

## SECTION 03

## Allowed data

Inputs to AI tools follow the institution's data classification scheme. Use this as a starting matrix and adjust per your policies:

- a Public information: allowed without restriction.
- a Internal information (procedures, drafts, summaries): allowed in approved tools only.
- a Confidential (customer data, NPI, account details, transaction data): not permitted in any AI tool unless the vendor agreement explicitly covers it and the tool runs in an approved private deployment.
- a Regulated data (BSA/AML detail, SARs, loan decisioning rationale, examination work product): not permitted.

## SECTION 04

## Human-in-the-loop requirement

AI outputs are draft work product. Every artifact that touches a customer, an examiner, or a regulated process requires documented human review before use.

- a The reviewer is identified by name and role on the artifact.
- a The reviewer attests that they verified factual claims, calculations, and any regulatory references.
- a Review evidence is retained for the period defined by [Institution]'s records retention schedule.

## SECTION 05

## Documentation

For AI-assisted work that produces a customer-facing or examiner-relevant artifact, staff document:

- a Which approved tool was used.
- a The prompt or instruction provided.
- a The data class of the input.
- a The human reviewer and date of review.

## SECTION 06

## Incidents

Suspected policy violations, prompt injections, model misuse, or accidental disclosure of regulated data follow the institution's existing incident response procedure with one addition:

- a Notify [Compliance owner] and [InfoSec owner] within 24 hours of discovery.
- a Preserve the prompt, output, and any downstream artifacts for review.
- a Do not delete tool history while the incident is open.

## SECTION 07

## Review cycle

This policy is reviewed at minimum annually and on any of the following triggers:

- a A new tool is added to the approved list.
- a A regulator issues new AI-specific guidance applicable to the institution.
- a An incident review surfaces a policy gap.

### SOURCE BASIS

- AIEOG AI Lexicon — US Treasury / FBIIC / FSSCC, Feb 2026
- SR 11-7 Model Risk Management Guidance
- Interagency TPRM Guidance

### ADAPT BEFORE ADOPTION

This is a starter template, not legal advice or an examiner-approved policy. Replace every [bracketed] placeholder, align the language with your institution's policies, and route the final document through compliance, risk, and legal review.